Section 03

Industrial Security (Bachelor)

Section 03 – Industrial Network Architectures

Industrial Network Architectures

Lecture Notes

Department of Computer Science

Section 03
Industrial Security (Bachelor)
Section 03 – Industrial Network Architectures
Industrial Network Architectures
Lecture Notes
Department of Computer Science

Outline – Section 03

Outline – Section 03 03
1 Purdue Reference Model
2 Topologies
3 Zones and Conduits

Learning Objectives

By the end of this section you will be able to

- Apply the Purdue Enterprise Reference Architecture.
- Explain the role of the Industrial DMZ.
- Compare common plant-floor topologies and their trade-offs.
- Apply the IEC 62443 concept of zones and conduits.
- Identify when to use a data diode or unidirectional gateway.

2026-05-18

Industrial Security (Bachelor)

└Learning Objectives

Learning Objectives 03

By the end of this section you will be able to

- Apply the Purdue Enterprise Reference Architecture.
- Explain the role of the Industrial DMZ.
- Compare common plant-floor topologies and their trade-offs.
- Apply the IEC 62443 concept of zones and conduits.
- Identify when to use a data diode or unidirectional gateway.

1

Purdue Reference Model

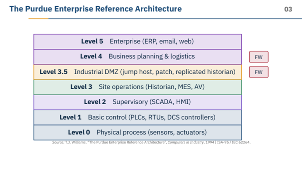
Section 03 – Industrial Network Architectures

1
Purdue Reference Model
Section 03 – Industrial Network Architectures

The Purdue Enterprise Reference Architecture

Level 5	Enterprise (ERP, email, web)	
Level 4	Business planning & logistics	FW
Level 3.5	Industrial DMZ (jump host, patch, replicated historian)	FW
Level 3	Site operations (Historian, MES, AV)	
Level 2	Supervisory (SCADA, HMI)	
Level 1	Basic control (PLCs, RTUs, DCS controllers)	
Level 0	Physical process (sensors, actuators)	

Source: T.J. Williams, "The Purdue Enterprise Reference Architecture", *Computers in Industry*, 1994 | ISA-95 / IEC 62264.

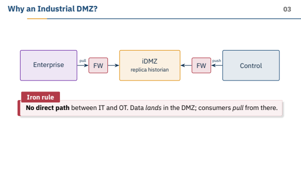


Williams' 1994 model is a teaching scaffold, not a building code — be honest with the room that real plants rarely match it cleanly. In most brownfield sites Level 2 and Level 3 are fused into one flat *plant network*, and Level 4/5 increasingly merge into a single cloud-fronted ERP. Pre-empt the IT instinct that "layers equal subnets" — a Purdue layer is a *trust boundary*, not a VLAN. Mention that ISA-95 (IEC 62264) is the standards-track sibling and that NIST SP 800-82 Rev. 3 still anchors its architecture chapter here. Transition: "If Layer 3.5 is the broker, what actually lives in it?" — next slide opens the iDMZ. Optional ask: "Where would a wireless mobile HMI sit — Level 2, Level 3, or floating?"

Why an Industrial DMZ?

Iron rule

No direct path between IT and OT. Data *lands* in the DMZ; consumers *pull* from there.



Pre-empt the common IT misconception: in IT a “DMZ” is usually one reverse-proxy host, in OT it is a whole tier — replica historian, WSUS/patch mirror, AV update relay, jump host, vendor remote-access broker. The iron rule is push from OT, pull from IT — never let an enterprise box initiate a TCP session into Level 2. Mention that “a firewall is enough” is the line auditors hear most often, and it is wrong without the DMZ tier — one rule mistake and you have a flat path from Outlook to a PLC. Practical reality: many plants run a Fortinet or Cisco ISA pair north and south of the DMZ from different vendors so a single CVE does not breach both. Transition: “Inside the plant, what does the wire actually look like?” Optional question: “Why is a replica historian safer than letting MES query the live one directly?”

2

Topologies

Section 03 – Industrial Network Architectures

2026-05-18

Industrial Security (Bachelor)

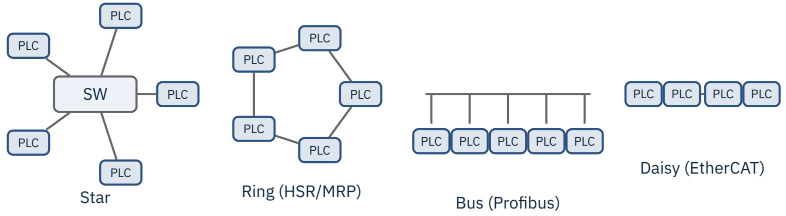
└Topologies

2

Topologies

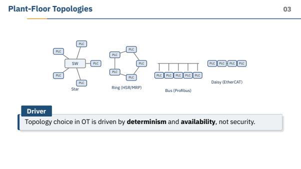
Section 03 – Industrial Network Architectures

Plant-Floor Topologies



Driver

Topology choice in OT is driven by **determinism** and **availability**, not security.



Drive home that topology in OT is picked for cycle-time guarantees and fail-over, not for blast-radius control — security has to layer on top. Star is what most greenfield Ethernet plants use with Hirschmann or Moxa managed switches; ring with MRP (IEC 62439-2) or HSR/PRP (IEC 62439-3) is the standard for substations and railway. Bus survives as Profibus DP on motor lines, and daisy chain shows up wherever EtherCAT or PROFINET IRT runs. Pre-empt the question “why not just star everything?” — because a star with one switch is one outage away from a stopped line; rings give zero-recovery fail-over. Transition: “Once we have a topology, how do we slice it into trust regions?” — next slide is zones and conduits. Optional class question: “Which topology would you pick for a 30-station bottling line and why?”

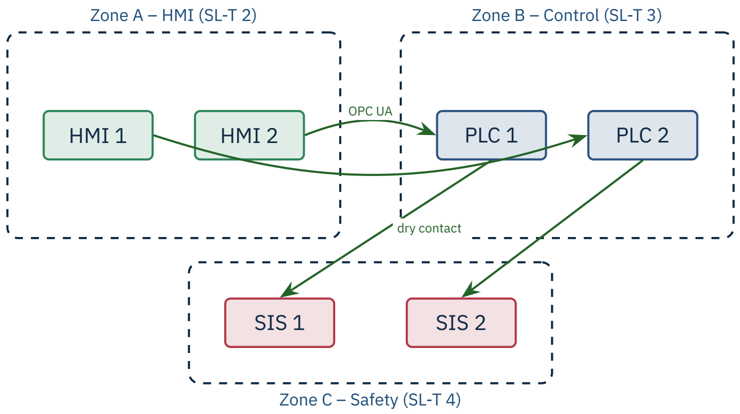
3

Zones and Conduits

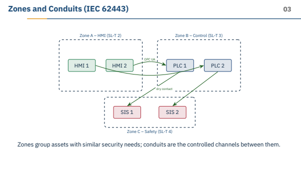
Section 03 – Industrial Network Architectures

3
Zones and Conduits
Section 03 – Industrial Network Architectures

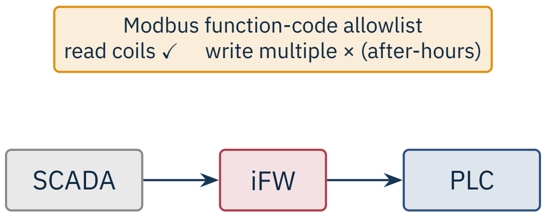
Zones and Conduits (IEC 62443)



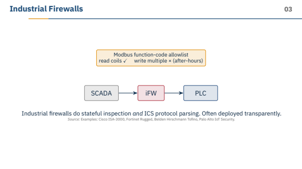
Zones group assets with similar security needs; conduits are the controlled channels between them.



Zones and conduits come from IEC 62443-3-2 — it is the only piece of vocabulary the standard insists you use during a risk assessment. The SL-T target on each zone is what an assessor will challenge, so explain that “SL-T 3” means “resists intentional violation by a skilled attacker with moderate resources”. Pre-empt the misconception that a zone is a VLAN — a zone is a *set of assets with a common security target*; the conduit is the only place you ever put a control. Note the safety zone (SIS, SL-T 4) is deliberately the smallest and is usually connected only by hard-wired dry contacts, not Ethernet — this is why Triton/Trisis in 2017 needed a Windows engineering workstation as a pivot. Transition: “So what enforces a conduit?” — next slide opens the industrial firewall. Optional question: “Could two zones share the same SL-T and still need a conduit between them?”

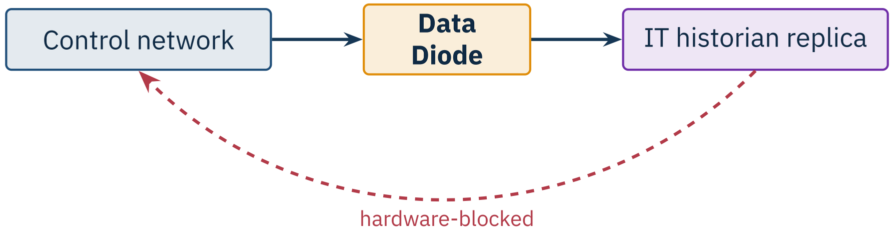


Industrial firewalls do stateful inspection *and* ICS protocol parsing. Often deployed transparently.
Source: Examples: Cisco ISA-3000, Fortinet Rugged, Belden Hirschmann Tofino, Palo Alto IoT Security.



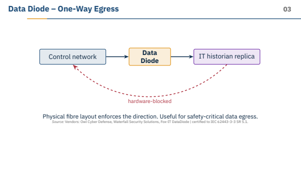
The differentiator is the deep-packet parser: a regular Fortinet or Palo can match TCP/502, but only the OT-aware variants (Tofino, ISA-3000 with Cisco Cyber Vision, Fortinet OT Security Service, Claroty/Nozomi-augmented appliances) actually read Modbus function codes, S7 job IDs, or DNP3 object groups. Stress that transparent (bump-in-the-wire) mode is the deployment style of choice — you can drop one in front of a legacy PLC without changing its IP. Pre-empt the misconception that an L4 firewall is enough: blocking everything except TCP/502 still lets an attacker write to coils; the allowlist must be at the function-code level. Mention that on small lines you can run Tofino in learning mode for a week to baseline, then flip to enforcement. Transition: “What if even allowlisted writes are too much — when do we want zero return path?” — next slide is the data diode. Optional question: “Why is after-hours write-blocking a useful default for a packaging line?”

Data Diode – One-Way Egress



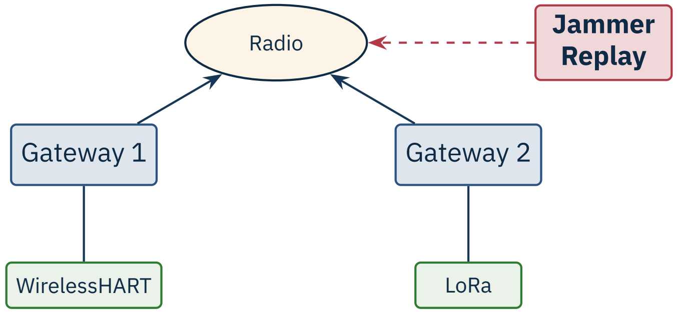
Physical fibre layout enforces the direction. Useful for safety-critical data egress.

Source: Vendors: Owl Cyber Defense, Waterfall Security Solutions, Fox-IT DataDiode | certified to IEC 62443-3-3 SR 5.1.

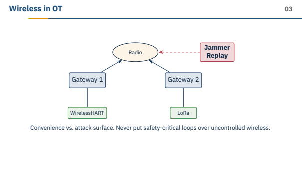


A real diode is two boxes bridged by a single fibre with the receive side physically removed on the high side — this is not a software setting, it is glass and a missing transceiver. Owl, Waterfall, and Fox-IT all ship the same primitive with different protocol proxies on top (OPC UA, historian replication, syslog, file transfer). Pre-empt the question “can we just configure the firewall one-way?” — no, because TCP needs a return ACK and any return path is a covert channel; a diode is the only way to make the impossibility of a reverse flow auditable. Practical reality: diodes are expensive (five-figure euros) and you only deploy them where the data is high-value but the flow is genuinely one-way — nuclear safety, pipeline SCADA egress, defence sites. Transition: “We have wired controls — what about radio?” — next slide is wireless. Optional question: “Why does UDP-based syslog cross a diode more easily than a TCP historian feed?”

Wireless in OT

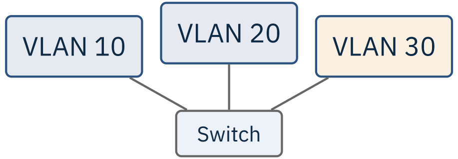


Convenience vs. attack surface. Never put safety-critical loops over uncontrolled wireless.



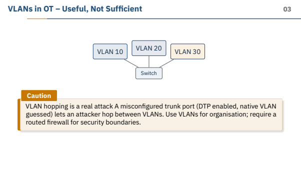
Wireless in OT is overwhelmingly driven by retrofit cost — WirelessHART (IEC 62591) and ISA-100.11a (IEC 62734) let you bolt a temperature transmitter onto a vessel without a cable tray. Both mesh, both use AES-128 join keys, and both are robust enough for non-critical monitoring loops — but jamming the 2.4 GHz band with a 20-euro SDR is trivial, so the slide's threat model is real. Pre-empt the misconception that "encrypted means safe" — encryption stops eavesdropping, not jamming or replay against the gateway. Mention LoRa fits long-range telemetry but its 1 % duty cycle and km range invite drive-by attackers; private 5G with a Nokia or Ericsson core is the new contender for high-density factories. Transition: "Wired or wireless, how do we slice a single switch into trust regions?" — next slide is VLANs. Optional question: "Would you ever close a control loop over Wi-Fi 6 — and if not, why not?"

VLANs in OT – Useful, Not Sufficient



Caution

VLAN hopping is a real attack A misconfigured trunk port (DTP enabled, native VLAN guessed) lets an attacker hop between VLANs. Use VLANs for organisation; require a routed firewall for security boundaries.



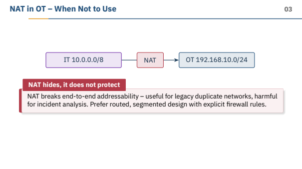
The misconception to break here is “VLANs equal segmentation” — they only do if every inter-VLAN packet is forced through a stateful firewall with deny-by-default ACLs. A Cisco Catalyst with default DTP and a guessed native VLAN gives away the plant: Yersinia or Scapy double-tag a frame and it pops out on the target VLAN. Practical guidance: hard-set every port to access mode, disable DTP, set the native VLAN to an unused bogus ID, and prune trunks. Mention that Moxa and Hirschmann managed switches default to safer settings than enterprise Cisco gear — vendor heritage matters. Transition: “VLANs split L2 — what about address translation at L3?” — next slide is NAT. Optional question: “If you only have unmanaged switches on a legacy line, what is your cheapest path to any segmentation at all?”

NAT in OT – When Not to Use

IT 10.0.0.0/8 — NAT → OT 192.168.10.0/24

NAT hides, it does not protect

NAT breaks end-to-end addressability – useful for legacy duplicate networks, harmful for incident analysis. Prefer routed, segmented design with explicit firewall rules.



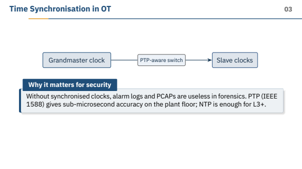
NAT survives in OT for one honest reason: every Siemens or Allen-Bradley skid arrives from the OEM hard-coded to 192.168.1.0/24, and when you buy four identical skids you need 1:1 NAT to make them coexist. Phoenix Contact mGuard and Hirschmann EAGLE devices are the workhorses for that pattern. Pre-empt the misconception that “the attacker can’t see us behind NAT” — once inside, NAT only frustrates the defender’s PCAP analysis because every packet looks like it came from the firewall. Mention that NAT also breaks IEC 61850 GOOSE and PROFINET DCP because both rely on Layer 2 multicast or hard-coded source IPs, so you cannot NAT a substation bus even if you wanted to. Transition: “Speaking of forensics — without synchronised clocks, your PCAPs are worthless.” Optional question: “If two identical skids share 192.168.1.10, how do you tell their logs apart on the central SIEM?”

Time Synchronisation in OT

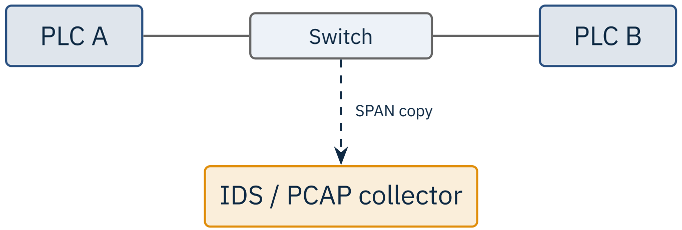
Grandmaster clock — PTP-aware switch → Slave clocks

Why it matters for security

Without synchronised clocks, alarm logs and PCAPs are useless in forensics. PTP (IEEE 1588) gives sub-microsecond accuracy on the plant floor; NTP is enough for L3+.

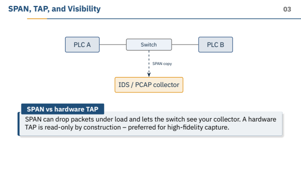


Time sync is the boring slide that decides whether a forensic investigation is possible. PTP (IEEE 1588-2019) needs hardware time-stamping in the switch silicon — Hirschmann RSP, Cisco IE-4000, and Moxa EDS-G500E all support it; an unmanaged 5-euro switch will ruin sub-microsecond accuracy. Pre-empt the misconception that “everyone uses NTP, it’s fine” — NTP’s 1–10 ms jitter is the difference between an alarm appearing before or after the safety trip in the log, and that ordering is what an investigator needs. Mention that the grandmaster should ideally have a GPS or GLONASS antenna on the roof, with a holdover oscillator for outages — and that GPS spoofing is a real OT attack vector (Iran’s 2011 RQ-170 capture being the canonical, if disputed, example). Transition: “Synchronised logs are only useful if we are actually capturing traffic — next slide is how.” Optional question: “Why is a 1 s clock skew between SIS and BPCS specifically dangerous?”



SPAN vs hardware TAP

SPAN can drop packets under load and lets the switch see your collector. A hardware TAP is read-only by construction – preferred for high-fidelity capture.



Visibility is where Nozomi, Claroty, and Dragos all earn their licence fees — but none of them work without a clean capture point. SPAN (Cisco) / mirror (Hirschmann, Moxa) is the cheap option: zero new hardware, but the switch CPU drops mirrored frames first when CPU spikes, so you lose exactly the traffic you wanted (anomalies). A Garland or Profitap aggregator TAP is passive optics or a relay — if power dies, traffic still passes; if the IDS dies, it cannot accidentally inject into production. Pre-empt the misconception that “the IDS is just listening, it cannot do harm” — a SPAN’d IDS still has a management interface, and that interface has been an entry vector (e.g. Claroty CTD CVEs in 2021–22). Mention you should always TAP both directions of a link, not just one half — one-way TAPs miss the response and confuse session reassembly. Transition: “We have looked at wired carefully — now compare the wireless options.” Optional question: “On a 1 Gbps link running at 60 % utilisation, would you trust a 1 Gbps SPAN port?”

Wireless Generations on the Plant

Tech	Latency	Range	Typical use
Wi-Fi 6 / 6E	1–10 ms	10–100 m	Mobile HMI, video
WirelessHART	250 ms	100 m	Process sensors
ISA-100.11a	250 ms	100 m	Process sensors
LoRaWAN	seconds	km	Building automation
NB-IoT / LTE-M	seconds	km	Remote telemetry
Private 5G	1 ms	100–500 m	High-density factory

Read this table left-to-right with the latency column as the primary axis — it tells you what kind of loop the technology can close. Wi-Fi 6E and private 5G are the only ones in the same order of magnitude as wired PROFINET RT, which is why Bosch, Siemens, and Audi are running 5G pilots on assembly lines (often with Nokia DAC or Ericsson Private 5G cores). WirelessHART and ISA-100.11a deliberately trade latency for battery life — a process transmitter that lasts five years on a D-cell. Pre-empt the misconception that “5G is just faster Wi-Fi” — 5G has SIM-based authentication, dedicated spectrum (in DE: 3.7–3.8 GHz Campus license from the Bundesnetzagentur), and QoS slicing that Wi-Fi cannot match. Mention LoRaWAN dominates building automation (lighting, HVAC sub-metering) but is almost never load-bearing for production. Transition: “That wraps the architecture tour — summary slide next.” Optional question: “Which row would you pick for a mobile torque wrench reporting bolt-tightness in real time?”

★ Key Takeaway: What to remember from this section

- The Purdue model groups assets into layers; firewalls separate the layers.
- The Industrial DMZ brokers all traffic between corporate IT and the plant.
- Zones and conduits give a structured language for IEC 62443 design.
- Hardware mediation (diodes, gateways) protects the most sensitive flows.

Summary – Section 03 03
★ Key Takeaway: What to remember from this section
• The Purdue model groups assets into layers; firewalls separate the layers.
• The Industrial DMZ brokers all traffic between corporate IT and the plant.
• Zones and conduits give a structured language for IEC 62443 design.
• Hardware mediation (diodes, gateways) protects the most sensitive flows.

Land the four bullets in this order: Purdue gives you the layer language, the iDMZ is the only mandatory broker, IEC 62443 zones-and-conduits is the assessor's vocabulary, hardware mediation (Owl/Waterfall diodes, Tofino allowlists) is the last line for the crown jewels. Preempt the exam-style temptation to memorise layer numbers — assessors care that students can defend a design choice, not recite Williams 1994. If you have time, throw one synthesis question on the screen: "Given a brownfield plant with one Cisco ASA between IT and OT and no DMZ, what are the first three things you change?" — expected answer: add an iDMZ tier, terminate inbound IT connections in it, push (not pull) plant data outward. Transition: references slide next; remind them the lab exercises for this section walk through building exactly this layout in the Docker stack. Optional question: "Which of the four takeaways would you sacrifice last if the budget got cut?"

References – Section 03

- Williams, T.J. *The Purdue Enterprise Reference Architecture*, Computers in Industry, 1994.
- ANSI/ISA-95 (IEC 62264). *Enterprise-Control System Integration*.
- IEC 62443-3-2:2020. *Security risk assessment for system design* (zones & conduits).
- IEC 62439-3:2021. *High Availability Seamless Redundancy (HSR) and Parallel Redundancy Protocol (PRP)*.
- IEEE 1588-2019. *Precision Time Protocol (PTP)*.
- IEC 62591:2016. *WirelessHART*.
- IEC 62734:2014. *ISA-100.11a wireless system for industrial automation*.
- Idaho National Lab. *Recommended Practice: Improving Industrial Control System Cybersecurity with Defense-in-Depth Strategies*, 2016.
- CISA. *Securing Network Infrastructure Devices*, 2018.
- Stouffer, K. et al. *NIST SP 800-82 Rev. 3 – Guide to OT Security*, Sep 2023.

References – Section 03 03

- Williams, T.J. *The Purdue Enterprise Reference Architecture*, Computers in Industry, 1994.
- ANSI/ISA-95 (IEC 62264). *Enterprise-Control System Integration*.
- IEC 62443-3-2:2020. *Security risk assessment for system design* (zones & conduits).
- IEC 62439-3:2021. *High Availability Seamless Redundancy (HSR) and Parallel Redundancy Protocol (PRP)*.
- IEEE 1588-2019. *Precision Time Protocol (PTP)*.
- IEC 62591:2016. *WirelessHART*.
- IEC 62734:2014. *ISA-100.11a wireless system for industrial automation*.
- Idaho National Lab. *Recommended Practice: Improving Industrial Control System Cybersecurity with Defense-in-Depth Strategies*, 2016.
- CISA. *Securing Network Infrastructure Devices*, 2018.
- Stouffer, K. et al. *NIST SP 800-82 Rev. 3 – Guide to OT Security*, Sep 2023.

End of Section 03

Industrial Network Architectures

Questions and discussion

End of Section 03
Industrial Network Architectures
Questions and discussion